

PE as a distribution channel: what a compliance startup actually needs to know

The "invest-then-deploy" model is real but widely misunderstood. No major PE firm has publicly acquired a cybersecurity or compliance company specifically to force-deploy it across a diversified portfolio. What actually happens is more pragmatic and, for a startup founder, potentially more actionable: PE firms build preferred vendor programs, mandate baseline security controls, and hire shared services providers who then select and deploy specific tools across portfolio companies. **52% of PE firms with over \$25 billion in AUM now maintain mandatory preferred vendor arrangements with pre-negotiated rates that portfolio companies must use.** (Help Net Security) This creates a genuine distribution channel — but the entry point is vendor partnership, not equity investment.

Three findings matter most for a cybersecurity compliance startup:

- **The buyer isn't the PE firm's investment team — it's the operating partner.** Technology and digital operating partners (now 19% of all operating partners) control tool selection. (Pressandassociates) The pitch isn't "invest in my company" but "I'll save your portfolio \$50K per company per year on compliance costs while reducing cyber risk by 60%."
- **CMMC 2.0 enforcement creates the most urgent PE compliance need right now.** Penalties reach \$100 million for non-compliance, CMMC went into effect (Vanta) December 16, 2024, and PE firms acquiring defense contractors have no choice but to solve this across their portfolios immediately.
- **Vanta and Drata haven't locked up the PE channel yet.** Vanta posted its first-ever PE/VC partnerships hire in 2025, (Built In NYC) meaning formal portfolio-wide distribution deals are still being built. The window for a purpose-built PE portfolio compliance platform is open.

The actual models PE firms use to deploy technology

The phrase "PE as a distribution channel" conflates several distinct mechanisms. Understanding which one applies determines the entire go-to-market strategy.

Preferred vendor programs represent the most common model. PE firms negotiate bulk pricing with technology vendors and either mandate or strongly recommend adoption across portfolio companies. (GetProven) KKR's Capstone team saved **over \$700 million** through centralized procurement by 2012. (Umbrex) These programs are formalized through platforms like GetProven (GetProven) and OMNIA Partners, which connect vendors directly to PE portfolio companies. For cybersecurity specifically, a February 2026 Kroll/QBE survey of 300 PE risk managers found that **95% of PE firms require basic technical controls** (MFA, privileged access management) across portfolios, and **97% require ongoing visibility** into portfolio company cybersecurity incidents. (Risk & Insurance)

Operational playbooks with standardized tech stacks define the Vista Equity Partners approach. Vista's consulting group — 100+ professionals operating as an in-house McKinsey — deploys proprietary standard operating procedures across all 90+ portfolio companies within months of acquisition. (Umbrex) (umbrex) Vista's OneVista program packages portfolio company software for cross-selling both internally and externally. (Vista Equity Partners) This model works because Vista's portfolio is exclusively software companies. The playbook's power was demonstrated when Vista acquired Marketo for **\$1.79 billion in 2016** and sold it to Adobe for **\$4.75 billion** just two years later. (Umbrex)

Shared cybersecurity services represent the emerging model most relevant to a compliance startup. Third-party firms like Fractional CISO, Emergent Security, and Ankura offer virtual CISO services specifically designed for PE portfolios. (Passle) (Fractional CISO) Emergent Security already deploys Vanta across PE portfolio companies for SOC 2 and ISO 27001 compliance. (Es1) RSM built its Sentry platform as a centralized cybersecurity dashboard for PE funds. (RSM US) **The vCISO is often the actual technology decision-maker** — they select and deploy specific tools across all companies they manage.

Buy-and-build consolidation is what Thoma Bravo does, but it's fundamentally different from cross-portfolio deployment. Thoma Bravo has invested in 24 cybersecurity companies worth **\$58 billion in aggregate enterprise value and \$6.5 billion in annual revenue**, (Thoma Bravo) including Proofpoint (\$12.3B), SailPoint (\$6.9B), and Darktrace (\$5.3B). (Wikipedia) But these are financial investments in cybersecurity companies, not deployments across non-cyber portfolio companies. Thoma Bravo grows these businesses operationally and exits them — SailPoint re-IPO'd at \$12.8 billion after being acquired for \$6.9 billion.

Which PE firms actually matter for a compliance startup

The firms most relevant to a compliance automation startup aren't necessarily the biggest names. They're the ones with dedicated operating teams, regulated-industry portfolios, and active cybersecurity programs.

Tier 1 targets include firms with formalized portfolio technology programs. **Hg Capital** (\$100B+ AUM, 58+ portfolio companies) (GrowthCap) acquired AuditBoard for over \$3 billion and invested in A-LIGN, a cyber compliance services firm (Hgcapitaltrust) — demonstrating direct appetite for compliance technology. Their "Hg Hive" operating model employs approximately 60 operating professionals including dedicated cybersecurity specialists. (Bain & Company) **Vista Equity Partners** (\$101B+ AUM, 90+ companies) operates the most systematized technology deployment in PE, (Vista Equity Partners +4) including a new "Agentic AI Factory" deploying AI across its entire portfolio with exclusive partnerships from Microsoft, Google, and AWS. (Vista Equity Partners) **KKR** (\$686B AUM) maintains Capstone (GrowthCap) with dedicated "Digital Value Creation" teams covering cybersecurity and data privacy across 100+ portfolio companies, (KKR) plus a Next Generation Technology Fund focused on cybersecurity.

Tier 2 targets are mid-market PE firms with sector concentration in regulated industries. Firms like **Audax Private Equity** (\$19B AUM, 175+ platforms, 1,400+ add-on acquisitions), (GrowthCap) **Accel-KKR** (\$23B+ cumulative commitments, focused on mid-market software), (Aventis) (GrowthCap) and **Francisco Partners** (\$45-50B AUM, 110+ companies including cybersecurity firms Forcepoint, Jamf, and BeyondTrust) (Softwareequity) present more realistic entry points for an early-stage startup. Mid-market firms with **20-50 portfolio companies** in healthcare, defense, or financial services represent the sweet spot — large enough for meaningful revenue, small enough to give a startup serious attention.

The defense-focused PE sub-segment deserves special emphasis. PE firms acquiring defense contractors face **CMMC 2.0 enforcement with penalties up to \$100 million**. (PreVeil) Summit 7 and PreVeil already market CMMC compliance specifically to PE firms, building shared compliance enclaves for multiple portfolio companies. (Summit 7) This is the highest-urgency, most mandate-driven segment of the market.

Five case studies reveal how the model works in practice

Vista Equity Partners and the Marketo transformation remains the most cited example of playbook-driven value creation. Vista acquired Marketo for \$1.79 billion in 2016, installed a new CEO aligned with

their standard operating procedures, restructured sales incentives, implemented contract management improvements, and standardized product development. Adobe acquired the transformed company for **\$4.75 billion in 2018 — a \$3 billion gain in two years.** (Umbrex) While this demonstrates operational deployment rather than technology cross-selling, it shows how standardized processes create outsized returns.

Thoma Bravo's identity platform consolidation illustrates the buy-and-build model. In 2022, Thoma Bravo spent \$12 billion acquiring three identity companies: SailPoint (\$6.9B), Ping Identity (\$2.8B), and ForgeRock (\$2.3B). (BankInfoSecurity) (Wikipedia) They merged ForgeRock into Ping Identity (SecurityWeek) in August 2023, creating a combined platform approaching \$1 billion in revenue. (Thoma Bravo) SailPoint was re-IPO'd in February 2025 at a **\$12.8 billion market cap,** (Yahoo Finance) with Thoma Bravo retaining a 76% stake. (Mostly metrics) Barracuda Networks was acquired for \$1.6 billion and sold to KKR for approximately \$4 billion (PitchBook +2) — a **2.5x return.**

Insight Partners and Kaseya/Datto shows how a PE-backed platform can become infrastructure for tens of thousands of companies. Insight invested in Kaseya in 2013, (Kaseya) backed 10+ acquisitions, and led the **\$6.2 billion acquisition of Datto in 2022.** (Business Wire) The combined platform now serves nearly 50,000 managed service providers in 170+ countries, (Kaseya) who collectively serve over a million SMBs. (Datto) This is the closest example to true portfolio-wide technology distribution — Kaseya's MSP customers function as a deployment channel reaching massive numbers of end-customer SMBs.

KKR Capstone's cross-portfolio procurement provides the best-documented example of centralized technology deployment across a diversified portfolio. KKR Capstone, with approximately 100 full-time operating professionals, (Yourkkrr) consolidated purchasing across portfolio companies and saved **over \$700 million by 2012** through bulk procurement. Their Green Portfolio Program generated **\$1.2 billion in savings** across 25 portfolio companies. (Umbrex) Today, Capstone includes dedicated cybersecurity centers of excellence (KKR) and partners with GPOs like OMNIA Partners for technology procurement.

Thoma Bravo's Cyber Consortium represents the most explicit cybersecurity knowledge-sharing initiative. Launched in April 2023, it brings together approximately 30 cybersecurity experts including executives from portfolio companies to share best practices. (Bain & Company) While not a technology deployment per se, it creates the infrastructure for standardized cybersecurity approaches across Thoma

Bravo's portfolio — and the Consortium's recommendations likely influence tool selection at portfolio companies.

The compliance automation market gap PE firms haven't filled

PE portfolio companies — typically mid-market businesses with 50-500 employees — face a perfect storm of cybersecurity pressure. **70% of ransomware attacks in 2024 targeted SMBs**, (Revealrisk) (DeepStrike) attacks on SMBs rose 16% in 2025, and the average breach costs an SMB **\$140,000** (Cinch I.T.) (with the global average reaching \$4.44 million for larger firms). (DeepStrike) Most PE portfolio companies lack a dedicated CISO, run patchwork security tools, and hold no compliance certifications.

The economics strongly favor automated compliance. Manual SOC 2 certification costs **\$50,000 to \$200,000** with consultants and auditors, takes 6-12 months, and often requires a dedicated compliance hire at **\$100,000-\$180,000 per year**. Automated platforms like Vanta and Drata cut this to **\$7,500-\$25,000 per year** (Cycoresecure) (Bright Defense) with audit readiness in 2-8 weeks. For a PE firm managing 30 portfolio companies, the difference between manual and automated compliance represents **\$1-5 million annually** in direct savings — before accounting for reduced breach risk, improved cyber insurance premiums, and enhanced exit valuations.

Compliance certifications directly impact PE exit economics. Companies lacking effective cybersecurity or unresolved past breaches attract lower valuations and can tarnish the PE firm's reputation. (Protiviti) Conversely, the World Economic Forum estimates that **substantial security improvements reduce losses by 60% and event probability by 67%**. (Impact My Biz) Compliance certifications also unlock enterprise sales opportunities for portfolio companies, (Es1) making them more competitive during the hold period.

The current market gap is a portfolio-level compliance platform. Vanta, Drata, and Secureframe are designed for individual companies. (Cycoresecure) None offers a true multi-tenant PE portfolio view with centralized dashboards showing compliance status across 20-50 companies simultaneously. Vanta only began hiring for PE partnerships in 2025. (Built In NYC) A startup purpose-built for portfolio-wide compliance deployment — with a PE admin dashboard, rapid multi-tenant onboarding, and cross-framework mapping — would occupy genuinely uncontested positioning.

An honest assessment of whether this trend is overhyped

The PE-as-distribution opportunity is **real but early-stage, and limited in specific ways** that matter for strategic planning.

It's real because the structural drivers are powerful. PE-backed companies now outnumber public companies **4:1 in the United States** (14,300 vs. 3,550). [tomtunguz](#) These companies average fewer than 500 employees, grow revenue at 7% annually, and their PE owners are actively seeking automation tools to improve margins. [tomtunguz](#) Regulatory pressure is intensifying: SEC Regulation S-P amendments require investment advisers with over \$1.5 billion AUM to implement formal incident response programs, with larger firms' compliance deadline having already passed in December 2025. Cyber insurance requirements now function as de facto compliance mandates — insurers require MFA, endpoint detection, incident response plans, and network segmentation as preconditions for coverage. [Risk & Insurance](#)

It's partially overhyped because execution is harder than the thesis suggests. **Only 7% of PE firms have fully integrated technology** across their portfolios [World Economic Forum](#) — 93% are still experimenting. Implementation timelines that vendors promise at 3 months routinely stretch to 6-12 months. [Ascendix](#) Portfolio company CEOs often resist top-down tool mandates from PE operating partners. [EY](#) And this capability is **concentrated in large PE firms** with dedicated operating teams. Mid-market and smaller PE firms — the more accessible targets for an early-stage startup — typically lack the infrastructure for systematic portfolio-wide technology deployment. [Help Net Security](#)

The most honest framing: PE portfolio companies represent a **highly attractive customer segment** that can be accessed through PE operating partners and preferred vendor programs. But the "single deal deploys to 50 companies overnight" scenario is rare. Reality is more like: prove value in 2-3 portfolio companies over 3-6 months, then gradually expand across the portfolio over 12-18 months, with some companies never adopting.

How to approach PE firms: a tactical playbook

The fundamental reframe: you are not seeking PE investment. PE firms invest in companies with proven revenue, not pre-seed startups. You are pitching yourself as a vendor that solves a portfolio-wide problem. Pursue traditional VC funding for capital. Use PE relationships for distribution.

Step 1: Build the right product features first. Before approaching any PE firm, the startup needs multi-tenant architecture that can spin up new portfolio company tenants rapidly, a portfolio-level admin dashboard showing compliance status across all companies, support for at least SOC 2 and one additional framework (ISO 27001 or CMMC), and its own SOC 2 Type II certification. Without these, no operating partner will take the meeting seriously.

Step 2: Enter through the side door. The most effective entry points are not the PE firms themselves but the intermediaries who already serve them. Target vCISO firms like Emergent Security, Fractional CISO, and Ankura — they select tools for portfolio-wide deployment. [Fractional CISO](#) Apply to join the **GetProven platform**, which 60% of Tier 1 VC/PE firms use for vendor discovery [GetProven](#) and which closed over \$58 million in vendor deals in a single year. [Getproven](#) Build relationships with PE-focused IT managed service providers like NexusTek, Omega Systems, and Sourcepass, who manage technology for PE portfolio companies. [Sourcepass](#)

Step 3: Land with 1-2 portfolio companies, then expand. Offer 2-3 pilot deployments at steep discounts (50-70% off or free for 90 days) to portfolio companies of a target PE firm. As Tomasz Tunguz of Theory Ventures emphasizes: PE firms prove value in one or two companies before rolling out to the entire portfolio. [Tomasz Tunguz](#) The first 100 days post-acquisition is the critical window [Privatecapitalglobal](#) when PE firms are most receptive to deploying new technology. [EY +4](#)

Step 4: Pitch the operating partner with portfolio-wide economics. Target Technology Operating Partners, VP of Portfolio Operations, or CISOs at the portfolio services level [Fortiumpartners](#) — find them on LinkedIn under "[PE Firm Name] Operating Partner." Frame the pitch as EBITDA improvement: "We reduce compliance costs by \$30,000-\$150,000 per portfolio company per year while cutting audit-readiness time from 6 months to 3 weeks. Across your 30 portfolio companies, that's \$1-4 million in annual savings and measurably reduced cyber risk at exit."

Step 5: Structure the deal correctly. Propose a Master Service Agreement covering all current and future portfolio companies at **\$5,000-\$10,000 per company per year** with a 30-50% portfolio discount for 10+ companies. Include a portfolio-level analytics dashboard as a premium feature. Avoid exclusivity clauses, rights of first refusal, and equity arrangements that would limit future fundraising or exit options. Set a hard internal rule: **no single PE firm should represent more than 25% of revenue.**

Step 6: Use PE traction to supercharge VC fundraising. "We deployed to 15 portfolio companies in 6 months through a single PE relationship" is an extraordinarily compelling VC fundraising metric. It demonstrates product-market fit, efficient distribution, and a repeatable GTM motion. The PE channel becomes the proof point, not the destination.

Conclusion

The PE-as-distribution-channel thesis holds up — but the mechanism is vendor partnership and preferred vendor programs, not equity investment or acquisition. The window is genuinely open: **compliance automation platforms haven't yet been purpose-built for PE portfolio deployment**, Vanta is only beginning to explore PE partnerships, [Built In NYC](#) and CMMC enforcement creates urgent mandatory demand. [Vanta](#) [PreVeil](#) The optimal strategy is not either/or: raise VC capital for independence and growth, while building PE distribution relationships for efficient customer acquisition. The startup that builds a true multi-tenant compliance platform with portfolio-level dashboards — and enters through vCISO firms and platforms like GetProven rather than cold-calling PE managing directors [GetProven](#) — will find a receptive market of 14,300 PE-backed companies that desperately need exactly this product.

[Tomasz Tunguz](#)